Daryadarcy App
Полный технический отчёт
аудит + FAQ + Роскомнадзор (14 пунктов)

Дата: 31.08.2026
Владелец: ИП Левина Дарья Сергеевна
Production: https://daryadarcy.com
Версия приложения: 1.0.0
Контакт для пользователей и Prodamus: daryadarcyapp@yandex.ru
Документ не содержит секретов, паролей и персональных данных пользователей.

1. Резюме

Daryadarcy - PWA/мобильное приложение бренда Darya Darcy: лента, видео, клуб по подписке, библиотека, магазин, интерактив (квиз). Backend на Node.js + tRPC, БД MySQL 8 (Timeweb), медиа - Timeweb S3, хостинг - VPS Timeweb (Россия).

Отдельного staging-окружения нет. Автотесты: 30 (Vitest). В августе 2026: оптимизация изображений (~192 МБ S3, ~85 МБ бандл), разделение push (marketing vs service), тариф клуба 6 мес / 4740 руб для зарубежных карт, шрифт Woolen для бренда, улучшения UX (загрузка, видео, клуб).

2. Окружения и роли

Окружение	URL / назначение
Production	daryadarcy.com - PWA + API
Локально	localhost:8081 (web), localhost:3000 (API)
Staging	Не развёрнут

Роли пользователей

- Гость - лента, видео, магазин, часть библиотеки
- Пользователь (users.role=user) - профиль, лайки, вход SMS/email
- Подписчик клуба - club_subscriptions активна - контент клуба, pen pals
- Администратор (role=admin) - CRUD контента, модерация

3. Технологический стек

- Клиент: React Native 0.81, Expo 54, Expo Router, TypeScript
- Web: Expo export (PWA), React Native Web
- API: Node.js, Express, tRPC 11, Zod, superjson
- БД: MySQL 8 utf8mb4, Drizzle ORM
- Файлы: Timeweb S3 (s3.twcstorage.ru)
- Auth: JWT cookie/Bearer, SMS.ru OTP, email+password (scrypt)
- Платежи: Prodamus (клуб, цифровые товары)
- Деплой: nginx + PM2 на VPS Timeweb

4. Персональные данные - поля профиля

Поле	Статус
Имя / ник (name)	Да - одно поле, отдельного псевдонима нет
Телефон	Да - вход по SMS, уникальный
Email	Да - вход, оплата, связь
Пол (gender)	Да - female / male
Аватар	Да - URL на S3
Дата рождения	Нет
Город в профиле	Нет - только в Pen pals (план: ФИО)
Пароль	Хеш scrypt - только email-вход

Дополнительные данные

- Pen pals: интересы (2-3), почтовый адрес, поле city (план: ФИО)
- Квиз: результат локально (AsyncStorage), не на сервере
- Лайки, сохранения, комментарии - привязка к userId
- Push-токен (Expo) - только native; marketing push - отдельное согласие

5. Авторизация

Способ	Сервис
SMS OTP	SMS.ru (sms.ru/sms/send), код SHA-256, TTL 5 мин
Email + пароль	Встроенная (/api/auth/register, /login)

Сторонних OAuth (Auth0, Firebase Auth, Яндекс ID) нет.

6. Инфраструктура и размещение данных

Компонент	Провайдер / страна
Backend API	Timeweb VPS, Россия (Санкт-Петербург, SPB-3)
База данных	Timeweb MySQL 8, SPB, Россия
Изображения	Timeweb S3 (s3.twcstorage.ru), bucket daryadarcy-s3, SPB
Резервные копии	Timeweb (MySQL/VPS) - параметры уточнить в панели

Timeweb: ООО ТАЙМВЭБ.КЛАУД, ИНН 7810945525. ЦОД: Санкт-Петербург (Selectel / Dataline). Точная зона SPB-1..4 - в панели Timeweb.

7. Аналитика и сторонние SDK

Сервис	Используется
Яндекс Метрика	Нет
Google Analytics	Нет
Sentry	Нет
Firebase	Нет
Expo	Да - фреймворк, не аналитика
Expo Push	iOS/Android; web - нет; трансграничная передача (США)
Google Fonts CDN	Нет - шрифты встроены локально (assets/fonts/)
Локальные шрифты	Playfair, EB Garamond, Gogol, Woolen (бренд)

8. Сроки хранения и удаление

- Удаление аккаунта по запросу: 14 раб. дней (вручную, daryadarcyapp@yandex.ru)
- После отмены подписки: 30 дней, затем удаление (политика)
- Pen pals "Удалить анкету": деактивация сразу
- Автоудаление по таймеру в коде: не реализовано
- Данные банковских карт не хранятся - Prodamus
- Marketing push: журнал push_consent_events (версия текста, дата, platform)
- club_payments / shop_purchases: orderId, email, сумма, статус
- Pen pals: 90 дней / 30 дней после обмена - запланировано, не внедрено

9. Безопасность и доступ специалистов

- Журнал admin-действий (audit log): не реализован - только PM2 logs
- 2FA доступа к БД: не настроена
- Admin: role=admin + JWT-сессия
- NDA специалистов: организационный документ - приложить отдельно

10. Почтовое отделение (Pen Pals)

Раздел для подписчиков клуба - подбор друга по переписке.

Текущая механика

- Автоматический подбор до 2 кандидатов по общим интересам (>=1)
- Полный почтовый адрес показывается сразу - без взаимного подтверждения
- Не пара 1:1 - односторонний показ кандидатов
- Отзыв заявки: кнопка "Удалить анкету" или email в поддержку

Запланированные доработки (по аудиту)

- Этап "Подтвердить обмен адресами" - адрес после 2 подтверждений
- Поле "Город" -> "ФИО"
- Отдельные юр. документы: согласие на передачу адреса, правила сервиса
- Срок хранения: до 90 дней до матча, 30 дней после обмена

11. Цифровые товары (магазин)

- Товары: digital-1 (пособие по фото), digital-2 (мастер-класс)
- Оплата: Prodamus, требуется вход + email в профиле
- После оплаты: запись shop_purchases, UI "Оплата получена"
- Файл на email: ручная отправка - автодоставки нет
- Раздел "Мои покупки" / скачивание в приложении: нет
- Без аккаунта (старый /api/pay/) - только email в Prodamus, в app не видно

12. Юридические документы

- Есть: Политика конфиденциальности + Условия (app/privacy, public/privacy.html)
- Нужно добавить: публичная оферта, политика возврата, согласие на ПДн, реквизиты ИП
- Pen pals: отдельные документы - в работе

13. Оптимизация производительности (август 2026)

- S3: 145 файлов оптимизировано, ~192 МБ экономии
- Бумажная текстура: 5.7 МБ -> 230 КБ
- Локальный бандл: PNG->WebP, JPG пересжатие (~120->~35 МБ assets)
- Скрипты: npm run optimize:s3, npm run optimize:assets

14. API (кратко)

tRPC: https://daryadarcy.com/api/trpc/ - auth, profile, feed, videos, club, admin, articles, shop, penPals, notifications.

Health: GET /api/health. REST: /api/auth/*, /api/prodamus/*, /api/pay/:id

15. База данных (таблицы без PII)

users, posts, post_media, tags, likes, saved_posts, videos, articles, club_subscriptions, club_payments, shop_purchases, post_comments, pen_pal_profiles, pen_pal_shown, push_tokens, push_consent_events, sms_codes.

Схема: drizzle/schema.ts, миграции drizzle/*.sql

16. Интеграции

- Timeweb MySQL, S3, VPS
- SMS.ru - OTP
- Prodamus - платежи
- YouTube - превью видео
- Expo Push - native уведомления

17. Автотесты

- __tests__/regression.test.ts - 18 тестов UI
- __tests__/quiz-data.test.ts - 12 тестов
- npm run verify - 30 тестов перед деплоем

18. Известные ограничения

- Нет staging-домена
- Нет E2E (Playwright/Detox)
- Pen pals без mutual confirm
- Marketing push: миграция 0015_push_consent.sql - применить на production MySQL
- Цифровые товары - без auto-delivery
- Нет audit log / 2FA БД

19. Правила аудита на production

Разрешено

- Просмотр публичных разделов, UI/UX, responsive
- Тестовые аккаунты (не owner admin)
- npm run smoke

Запрещено

- Редактирование реальных постов без согласования
- Нагрузочное тестирование, реальные платежи
- Доступ к .env, SSH, БД, S3-ключам
- Экспорт персональных данных

20. Комплект поставки

- Архив исходников: daryadarcy_app_backup_YYYY-MM-DD.zip (~230 МБ)
- docs/ - AUDIT-PACKAGE, API, DATABASE-SCHEMA, INTEGRATIONS, KNOWN-ISSUES
- README.md, .env.example

- Не входит: .env, пароли, PII, полные server logs
- Тестовые аккаунты и NDA - отдельно

21. Push-уведомления (сервисные и рекламные)

Тип	Примеры / согласие
Сервисные	Оплата, подписка - без marketing opt-in
Рекламные	Новые посты, акции - только после явного согласия

В профиле (native): переключатель "Получать новости, новые публикации, акции". По умолчанию выключен. Backend: notifications.marketingConsent, setMarketingConsent, sendMarketingPostNotification фильтрует по согласию.

Трансграничная передача: Backend (РФ) -> Expo Push API (США) -> APNS/FCM. В push не передаются ФИО, адреса, платёжные данные - только заголовок и превью.

- Журнал: push_consent_events (userId, type, status, version, platform, date)
- Admin: purgeUserPushData при удалении аккаунта
- Документация: docs/PUSH-NOTIFICATIONS.md

22. Список задач по приложению (22 пункта)

Источник: "Задачи по приложению daryadarcy". Статус на 31.08.2026. DONE = реализовано в коде; WAIT = нужны тексты/решение; PLAN = в дорожной карте.

1	Загрузка: убрать пустой экран, спиннер, "Повторить", сжать изображения	DONE 31.08
2	Email daryadarcyapp@yandex.ru в документах и для связи	DONE 31.08
3	Prodamus: зарубежные карты, 6 мес = 4740 руб, доступ к клубу	DONE 31.08
4	Блокировка нарушителей в клубе - как реализовать?	WAIT решение
5	Юр. раздел: оферта, ПД, cookie, реквизиты	WAIT тексты
6	Разделить push: сервисные / рекламные с opt-in	DONE 28.08
7	Pen pals: 18+, согласие, mutual confirm, автоудаление	PLAN
8	Pen pals: поле "Город" -> "ФИО"	PLAN
9	Профиль: управление подпиской, отмена автопродления, возврат	PLAN
10	Удаление аккаунта через 30 дней, обезличить комментарии	PLAN
11	Чат по средам: комментарии, 2 фото, ссылки, закрытие 2 суток	PLAN
12	Комментарии: удаление, жалобы, модератор, блокировка	PLAN
13	Безопасность: роли, 2FA admin, audit log, бэкапы	PLAN
14	Формы согласий: отдельные checkbox, версия и дата	PLAN
15	Автоотправка пособия/МК на email за 15 мин	PLAN
16	Клуб: оригинальная ориентация постов (не 4:5)	DONE 31.08
17	Качество обложек видео в клубе	WAIT исходники
18	Форматирование текста (ссылки, выделения)	PLAN
19	Шрифт DARYADARCY -> Woolen	DONE 31.08
20	Главная: карусель между "об авторе" и книгой	WAIT обложки
21	Видео: шиповники как на "Интерактив"	DONE 31.08
22	Видео: жирные названия; эффект "Тайный сад"	DONE 31.08

Итого: 11 выполнено, 4 ожидают материалы/решения, 7 в дорожной карте.

23. Сведения для Роскомнадзора (кратко)

Оператор

ИП Левина Дарья Сергеевна. Сайт: https://daryadarcy.com

Инфраструктура Timeweb (данные из панели, 31.08.2026)

Сервис	Параметры
MySQL Charming Aquila	ID 4202401, IP 77.95.206.157, MySQL 8.4
Зона MySQL / S3	ru-1 = SPB-3, Санкт-Петербург
Адрес ЦОД SPB-3	Dataline, ул. Жукова, д. 43, СПб
S3 daryadarcy-s3	ID 513637, регион ru-1, endpoint s3.twcstorage.ru
VPS daryadarcy-main	ID 8271015, IP 200.165.234.36, Cloud MSK 50 (Москва)

Даты начала (история Timeweb)

- S3 daryadarcy-s3: 5 июня 2026
- VPS daryadarcy-main (Ubuntu 24.04): 5 июня 2026
- MySQL Charming Aquila: 24 августа 2026
- Для заявления: начало обработки ПДн - не ранее 5 июня 2026 (инфраструктура); уточнить дату первых пользователей

Резервные копии

- MySQL: физические бэкапы включены, ежедневно с 00:15 МСК, хранится 1 копия (с 24.08.2026)
- MySQL: логические бэкапы выключены
- VPS: автобэкапы диска включены (последний: 31.08.2026 13:00)
- Логи PM2/nginx на VPS: срок ротации в коде не задан - уточнить на сервере

Обработчики / инфраструктура

Контрагент	ИНН / роль
ООО ТАЙМВЭБ.КЛАУД	7810945525 - VPS, MySQL, S3, РФ
ООО СМС.РУ	7713461582 - OTP SMS, РФ
ООО Продамус	1215156909 - платежи, РФ
Expo / Apple APNS / Google FCM	push-токены, текст push, США
Google (YouTube CDN)	превью видео, США

Категории персональных данных

- Профиль: имя, email, телефон, пол, аватар, хеш пароля -> MySQL users
- SMS OTP: телефон, хеш кода -> sms_codes (TTL 5 мин)
- Подписка/оплата: orderId, email, сумма -> club_payments, club_subscriptions
- Магазин: orderId, email, productId -> shop_purchases
- Pen pals (опционально): интересы, город, почтовый адрес -> pen_pal_profiles
- Push: Expo token, platform; marketing consent -> push_tokens, push_consent_events
- Не храним: банковские карты (Prodamus), дату рождения, результат квиза (локально)

Трансграничная передача

Да: native push через Expo/APNS/FCM (США); превью YouTube (США). Цель: доставка уведомлений и отображение превью. Полная карта: docs/ROSKOMNADZOR-DATA-MAP.md

Чеклист перед подачей (для ИП)

- Реквизиты ИП и дата начала сбора ПДн
- Скрин Timeweb: зона MySQL/S3 и параметры бэкапов

- Обновить политику конфиденциальности (push, Timeweb, трансграничная передача)
- NDA с техническим специалистом (организационно)

24. Шрифт Woolen (бренд)

- Лицензия: куплена для сайтов; EULA в assets/fonts/Woolen-EULA.txt
- Файлы: Woolen-Regular.ttf (app), .woff / .woff2 (web)
- Применение: надпись DARYADARCY на главной, login, privacy, site
- Извлечение: npm run extract:woolen (из Woolen.zip)
- Google Fonts CDN не используется - все шрифты локально

25. Ответы на вопросы (31.08.2026)

Краткие ответы для ИП и заявления в Роскомнадзор.

Регистрация и аккаунт без клуба

Отдельная бесплатная регистрация ради регистрации не обязательна. Основной путь в клуб: оплата -> запись в базе -> вход.

- Без входа: лента, видео, магазин, часть библиотеки - как гость
- Клуб - только после оплаты; при оплате указывается email или аккаунт
- Вход: SMS (телефон) или email + пароль
- Полный личный кабинет DARCY (профиль, сохраненное, клуб) - только для участниц клуба

Итого: основные пользователи клуба - оплатившие и авторизовавшиеся; гостевой просмотр без регистрации тоже есть.

Подписка 6 мес. / 4740 руб. (зарубежные карты)

В коде: ровно 180 календарных дней с даты оплаты (или с конца текущего доступа, если подписка уже была). Это не 6 календарных месяцев (напр. 15 января -> 15 июля).

В тексте оплаты написано "6 месяцев", в системе считается 180 дней. Для документов рекомендуется: "180 дней (6 месяцев) с даты оплаты".

Push-уведомления

- Web/PWA: push сейчас нет - ни технически, ни в интерфейсе
- Переключатель согласия на рекламные push - только native iOS/Android
- На сайте переключатель не показываем до запуска push в PWA
- Backend-логика согласия готова про запас; для web не активируем

Для РКН: Expo Push в web/PWA сейчас не используется.

Роскомнадзор - дополнения

1. ЦОД MySQL, S3 и бэкапов

MySQL (Charming Aquila, 4202401) и S3 (daryadarcy-s3): зона ru-1 / SPB-3, Санкт-Петербург, Dataline, ул. Жукова, д. 43. VPS API (daryadarcy-main): Cloud MSK 50, Москва (ПД хранятся в MySQL SPB, не на диске VPS). Бэкапы MySQL: ежедневно, 1 копия. Бэкапы VPS: включены.

2. Срок логов, бэкапов, дата начала обработки

- Бэкапы MySQL: ежедневно с 00:15 МСК, хранится 1 копия

- Бэкапы VPS: автоматические, на диске сервера
- Логи PM2/nginx: срок ротации - уточнить на VPS
- Инфраструктура с 5.06.2026 (S3/VPS), MySQL с 24.08.2026
- Дата первых пользователей с ПДн - указывает ИП

3. Expo Push в web/PWA

Нет, не используется. Только для будущих native-сборок iOS/Android.

4. Запросы к YouTube/Google до действия пользователя

Что	Когда
Превью видео (обложки)	Да - вкладка Видео; proxy -> i.ytimg.com; без ФИО/email
Само видео	Нет - только по нажатию play
Переход на youtube.com	Только если пользователь сам нажал ссылку
Google Fonts	Нет - шрифты локально на сервере

5. Меры защиты - уже внедрено

- HTTPS (TLS), пароли scrypt, SMS-коды SHA-256 TTL 5 мин
- JWT-сессии, роли user/admin, проверка подписи Prodamus webhook
- Рекламные push - только после согласия + журнал push_consent_events
- Банковские карты не храним (Prodamus), политика конфиденциальности в app

Не внедрено (указать в заявлении честно)

- Журнал admin-действий, 2FA, автоудаление аккаунтов по таймеру
- Автобэкапы из кода приложения (бэкапы - через Timeweb, если включены)

Полные ответы на 14 вопросов для уведомления РКН - раздел 27.

27. Уведомление Роскомнадзора - ответы (14 пунктов)

Только подтвержденные данные: код, nginx-конфиг, панель Timeweb 31.08.2026. Без предположений там, где указано "уточнить".

1. Адрес ЦОД MySQL и S3 (ФИАС)

MySQL Charming Aquila ID 4202401, IP 77.95.206.157. S3 daryadarcy-s3 ID 513637, регион ru-1. Зона ru-1 = SPB-3 (таблица Timeweb Cloud). Площадка SPB-3: Dataline, г. Санкт-Петербург, ул. Жукова, д. 43. Для формы: адрес в формате ФИАС - подобрать код на fias.nalog.ru по этому адресу (в коде приложения кода ФИАС нет).

2. Московский VPS и персональные данные

VPS daryadarcy-main, IP 200.165.234.36, Cloud MSK 50 (Москва). Основная БД ПДн - MySQL в Санкт-Петербурге, не на диске VPS. На VPS: журналы nginx/PM2, временная обработка запросов. Локальной копии БД пользователей нет. В уведомлении: БД - СПб; VPS - место обработки и хранения технических журналов, не основная база ПДн.

3. Адрес московского ЦОД (Cloud MSK 50)

В панели Timeweb для VPS указан только тариф Cloud MSK 50 (Москва), конкретный адрес здания ЦОД в интерфейсе не отображается. Точный адрес - запрос в поддержку Timeweb или указание: Россия, г. Москва, инфраструктура Timeweb Cloud (тариф Cloud MSK 50). По документации Timeweb MSK-1 (ru-3): IXcellerate, DataPro и др.

4. ПДн в журналах PM2/nginx

- Да: IP-адрес, URL запроса, User-Agent, метод, код ответа, время
- Нет намеренно: телефон, email, ФИО, пароли, SMS-коды, содержимое JWT
- PM2: возможны orderId/userId в отладочных строках webhook Prodamus - не полные ПДн

5. Срок хранения и ротация журналов PM2/nginx

В репозитории проекта настройки logrotate и сроков PM2/nginx не заданы. Фактический срок - только на VPS. Для уведомления: уточнить на сервере или у Timeweb.

6. Резервные копии VPS

Из панели Timeweb: автобэкапы диска VPS включены, последняя копия 31.08.2026 13:00. Не подтверждено из панели: физический ЦОД хранения бэкапов, число копий, срок удаления. Ожидаемо: РФ, инфраструктура Timeweb - уточнить в поддержке или скрином раздела Бэкапы VPS.

7. MySQL backup - подтверждение

Да. Физические бэкапы включены. Ежедневно с 00:15 МСК. Хранится 1 копия. При создании новой предыдущая заменяется. Логические бэкапы выключены. Источник: панель Timeweb, кластер 4202401, 31.08.2026.

8. Шифрование HTTPS/TLS - поля формы РКН

- Сертификат: Let's Encrypt (/etc/letsencrypt/live/daryadarcy.com/)
- Протоколы: TLS 1.2, TLS 1.3 (nginx deploy/nginx-daryadarcy.conf)
- Реализация: nginx + OpenSSL (Ubuntu 24.04 на VPS)
- Сертифицированные СКЗИ (ГОСТ): не используются

Заполнение формы: да - HTTPS; класс СКЗИ - не применяется / не сертифицированные СКЗИ; TLS 1.2/1.3, OpenSSL, сертификат Let's Encrypt (ISRG). Версию OpenSSL на сервере (openssl version) добавить после проверки на VPS.

9. YouTube - встроенный плеер или внешняя ссылка

- В приложении: HTML5 video, src=/api/yt/{id} - proxy через backend, не iframe YouTube
- Кнопка "Смотреть на YouTube" - внешняя ссылка только по нажатию пользователя
- Если videoUrl на S3 - воспроизведение с Timeweb S3 без YouTube

10. Загрузка ресурсов YouTube/Google до действия пользователя

Сценарий	До действия пользователя
Список видео (превью)	Да - /media/yt-thumb/ -> i.ytimg.com; ID ролика; cookie Google отбрасываются
iframe/скрипты/cookie Google на странице	Нет
Google Fonts CDN	Нет - шрифты локально
Страница ролика	Запрос /api/yt при открытии страницы ролика

При воспроизведении: IP и User-Agent браузера; email/телефон/userId DARYADARCY в YouTube не передаются.

11. Передает ли backend данные пользователя в YouTube/Google

При /api/yt/{id}: yt-dlp запрашивает youtube.com/watch?v={id}. Email, телефон, userId, имя не передаются. User-Agent и IP VPS (200.165.234.36). Превью: nginx -> i.ytimg.com, только ID ролика. Переход на youtube.com -

из браузера пользователя, backend не участвует.

12. Push в web/PWA

Подтверждаем: Expo Push, APNs, FCM в web/PWA не используются. Push-tokens не собираются и не хранятся (registerNativePush только при Platform.OS != web). UI согласия на push в профиле на web скрыт.

13. Google Fonts, Analytics, Metrika, Firebase, Sentry

Подтверждаем - не используются в production web/PWA: Google Fonts CDN, Google Analytics, Яндекс.Метрика, Firebase Analytics, Sentry. Шрифты - локально в assets/fonts. @expo-google-fonts - npm-пакет с локальными файлами.

14. Меры защиты - фактически работают

Мера	Статус
HTTPS/TLS Let's Encrypt	работает
Пароли scrypt	работает
SMS SHA-256, TTL 5 мин	работает
JWT-сессии (jose)	работает
Подпись webhook Prodamus	работает
Роли user/admin	работает
Бэкап MySQL ежедневно	работает (Timeweb)
Бэкап VPS	включен (Timeweb)

Не внедрено: audit log admin, 2FA, автоудаление аккаунтов, авторотация логов (не в репозитории).

Чеклист перед подачей (осталось у ИП / Timeweb)

- Код ФIAS для ул. Жукова, д. 43, СПб - fias.nalog.ru
- Точный адрес московского ЦОД VPS - Timeweb поддержка
- Срок ротации логов PM2/nginx - проверка на VPS
- Параметры бэкапов VPS (число копий, регион) - скрин Timeweb
- Дата начала обработки ПДн пользователями - указывает ИП

28. Контакты

Владелец / оператор: ИП Левина Дарья Сергеевна

Email для пользователей и Prodamus: daryadarcyapp@yandex.ru

Сайт: https://daryadarcy.com

Технические вопросы аудита - к разработчику проекта.

Полный комплект markdown: docs/AUDIT-PACKAGE.md, ROSKOMNADZOR-DATA-MAP.md, PUSH-NOTIFICATIONS.md